

Security+ 2.3 · Supply Chain Vulnerabilities

Mestre CyberSec · Aula 2.3 — Supply Chain Vulnerabilities (9:12) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Atacar o ELO que tu confias: software comprometido (SolarWinds), componente de terceiros, chip de hardware malicioso, library de código (npm/pip), open-source package sem dono claro. O atacante injeta código no CANAL CONFIÁVEL — todo mundo baixa espalha pra ele. Defesa: SBOM (lis

💡 Highlights que a prova CompTIA cobra

- Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar
- SolarWinds: o caso clássico (18k empresas)
- SBOM = Software Bill of Materials — lista de componentes do software

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'list of software components' = SBOM
- 'checks dependencies for known vulnerabilities' = SCA

Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.3 — Supply Chain Vulnerabilities)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque à Cadeia de Suprimentos (N/A)

Ataque que compromete um fornecedor, distribuidor ou canal confiável para entregar código ou hardware malicioso aos clientes downstream.

 **Armadilha CompTIA:** *Lembre-se: o atacante não invade você diretamente; ele envenena o canal confiável que você já confia.*

• Ataque SolarWinds (N/A)

Caso clássico de ataque à cadeia de suprimentos em que atores comprometeram atualizações do SolarWinds Orion para distribuir malware a cerca de 18.000 organizações.

 **Armadilha CompTIA:** *Se a prova citar atualização de software confiável usada para espalhar backdoor, pense em SolarWinds.*

• Lista de Materiais de Software (SBOM)

Inventário legível por máquina de todos os componentes, bibliotecas e dependências de software, usado para identificar e gerenciar riscos da cadeia de suprimentos.

 **Armadilha CompTIA:** *'List of software components' na prova = SBOM. Não confunda com SCA, que verifica vulnerabilidades.*

• Análise de Composição de Software (SCA)

Ferramenta ou processo automatizado que examina dependências e componentes de software em busca de vulnerabilidades conhecidas, problemas de licença e bibliotecas desatualizadas.

 **Armadilha CompTIA:** *'Checks dependencies for known vulnerabilities' = SCA. SBOM é a lista; SCA é a análise.*

• Componente de Terceiros (N/A)

Qualquer biblioteca, módulo, SDK ou serviço externo integrado a uma aplicação, introduzindo risco se for vulnerável, malicioso ou sem suporte.

 **Armadilha CompTIA:** *Componente de terceiros amplia a superfície de ataque; a organização ainda é responsável pelo risco.*

• Chip de Hardware Malicioso (N/A)

Implantação de hardware ou componente falsificado inserido durante a fabricação ou distribuição que pode criar backdoors, exfiltrar dados ou inutilizar um dispositivo.

 **Armadilha CompTIA:** *Ameaça de cadeia de suprimentos de hardware: chip malicioso é difícil de detectar e pode vir de fornecedor comprometido.*

• Risco de Pacote Open-Source (N/A)

Risco do uso de pacotes open-source públicos que podem estar sem manutenção, sem dono claro ou vulneráveis a typosquatting ou dependency confusion.

 **Armadilha CompTIA:** *Pacote open-source sem dono claro ou desatualizado é vulnerabilidade de cadeia de suprimentos; nem todo código público é seguro.*

• Canal Confiável (N/A)

Canal legítimo de comunicação ou atualização, como updates de fornecedores ou lojas de aplicativos, que atacantes abusam para entregar conteúdo malicioso porque os usuários confiam nele.

 **Armadilha CompTIA:** *Frase-chave: 'atacante injeta código no canal confiável'. A defesa deve validar integridade mesmo em canais confiáveis.*

Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A equipe de TI de uma empresa de médio porte instalou uma atualização de rotina da sua plataforma corporativa de monitoramento de rede, baixada diretamente do servidor de atualizações do fornecedor e assinada com o certificado de assinatura de código válido do fabricante. Meses depois, investigadores confirmaram que o pipeline de build do fornecedor foi comprometido e que a atualização continha um backdoor que se comunicava com um servidor externo. Qual fator tornou esse ataque de cadeia de suprimentos eficaz contra os controles antimalware já existentes na empresa?

- A) A carga foi compactada com um packer comercial que os motores de análise não inspecionam dentro de instaladores confiáveis.
- B) O código malicioso chegou dentro de uma atualização assinada digitalmente pelo fornecedor confiável, de modo que as verificações de confiança, hash e reputação foram todas aprovadas.
- C) A atualização desativou o registro de logs do endpoint antes de instalar a carga, impedindo qualquer registro da instalação.
- D) O ataque dependeu de um chip de hardware no servidor do fornecedor, portanto nenhum tráfego de rede foi gerado.

QUESTÃO 2 · CENÁRIO DE EXAME

Um fabricante de software para a área de saúde agora precisa responder a clientes e reguladores sobre cada componente open-source e de terceiros embutido em seu produto, incluindo versões exatas e dependências transitivas. Qual entrega MELHOR atende a esse requisito?

- A) Um software bill of materials (SBOM) gerado a cada release e atualizado em cada build.
- B) Um relatório de teste de intrusão cobrindo a aplicação compilada e suas APIs expostas.
- C) Uma varredura de vulnerabilidades nos servidores de produção que hospedam a aplicação.
- D) Um inventário de ativos listando servidores, endpoints e dispositivos de rede do ambiente corporativo.

QUESTÃO 3 · CENÁRIO DE EXAME

Durante uma revisão de código, um desenvolvedor percebe que a aplicação da equipe utiliza dezenas de pacotes de terceiros, vários dos quais trazem suas próprias dependências. A gestão quer uma forma automatizada de identificar versões vulneráveis conhecidas e conflitos de licença nesses componentes a cada build. Qual solução MELHOR atende ao requisito?

- A) Agentes de runtime application self-protection (RASP) instalados em hosts de produção.
- B) Static application security testing (SAST) configurado para analisar apenas o código-fonte original da equipe.
- C) Software composition analysis (SCA) integrado ao pipeline de CI/CD.
- D) File integrity monitoring (FIM) nos arquivos do sistema operacional do servidor de build.

QUESTÃO 4 · CENÁRIO DE EXAME

Após uma auditoria de segurança, uma organização descobre que vários de seus switches centrais foram comprados de um intermediário terceirizado em vez de um revendedor autorizado, e que o firmware desses dispositivos não corresponde aos hashes publicados pelo fabricante. Qual ação MELHOR reduz esse risco de cadeia de suprimentos de hardware daqui em diante?

- A) Habilitar port security e 802.1X em todas as portas dos switches.
- B) Adquirir hardware de rede apenas por canais autorizados e verificar os hashes do firmware assinado pelo fabricante antes da implantação.
- C) Mover todo o tráfego de gerenciamento para uma rede out-of-band protegida por ACLs.
- D) Implantar uma solução de network access control (NAC) para perfilar os endpoints conectados.

QUESTÃO 5 · CENÁRIO DE EXAME

Um desenvolvedor precisa de uma biblioteca HTTP popular em Python e instala um pacote cujo nome difere por um caractere do pacote legítimo. O script de instalação do pacote exfiltra silenciosamente variáveis de ambiente, incluindo tokens de CI/CD, do servidor de build. Qual controle MELHOR previne esse tipo de ataque?

- A) Impor um repositório interno curado de pacotes, com allowlist de pacotes aprovados e versões de dependência travadas.
- B) Executar o servidor de build em um contêiner com sistema de arquivos raiz somente leitura.
- C) Exigir autenticação multifator para todas as contas de desenvolvedor.
- D) Habilitar registro detalhado de todas as consultas DNS de saída do servidor de build.

QUESTÃO 6 · CENÁRIO DE EXAME

Um atacante compromete as credenciais de um desenvolvedor e envia um commit malicioso que passa pela revisão por pares porque a alteração está escondida dentro de um script de build ofuscado. O artefato resultante é publicado aos clientes como uma release normal. Qual controle MELHOR limita o impacto de um atacante que já alcançou o pipeline de build?

- A) Exigir commits assinados e assinar criptograficamente os artefatos de release com uma chave exclusiva de build à qual os desenvolvedores não têm acesso.
- B) Aumentar a frequência das atualizações automatizadas de dependências.
- C) Adicionar um web application firewall na frente do portal voltado ao cliente.
- D) Restringir os notebooks dos desenvolvedores à VLAN corporativa.

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa planeja contratar um provedor de folha de pagamento em nuvem que processará informações pessoais identificáveis dos funcionários. Antes de assinar o contrato, a equipe de segurança precisa determinar se os controles do provedor são adequados. Qual atividade MELHOR apoia essa decisão?

- A) Executar uma varredura externa de vulnerabilidades na página de login pública do provedor.
- B) Analisar o relatório de auditoria independente do provedor (por exemplo, SOC 2 Type II) e preencher um questionário de avaliação de risco de fornecedor.
- C) Solicitar o whitepaper de marketing do provedor e sua lista de localizações de data center.
- D) Testar a recuperação de desastres do provedor provocando uma indisponibilidade simulada em sua API de produção.

QUESTÃO 8 · CENÁRIO DE EXAME

Um alerta de um CERT nacional avisa que uma biblioteca de logging open-source amplamente usada recebeu um backdoor em uma versão específica publicada há duas semanas. Um analista de segurança precisa determinar quais aplicações internas estão expostas. Qual ação o analista deve tomar PRIMEIRO?

- A) Bloquear todo o tráfego de saída da unidade de negócio afetada.
- B) Consultar o inventário de SBOM e SCA para identificar quais aplicações e imagens de contêiner incluem a versão comprometida.
- C) Notificar todos os clientes de que seus dados podem ter sido vazados.
- D) Reconstruir todos os servidores do data center a partir de uma imagem padrão.

QUESTÃO 9 · CENÁRIO DE EXAME

Uma aplicação de pagamentos depende de uma biblioteca open-source cuja última versão foi publicada há quatro anos; o mantenedor original é inacessível e não existe projeto sucessor. Qual ação MELHOR trata o risco de cadeia de suprimentos de longo prazo desse componente?

- A)** Aceitar o risco, pois o código da biblioteca não mudou e, portanto, nenhuma nova vulnerabilidade pode surgir.
- B)** Substituir a biblioteca por uma alternativa mantida ativamente, ou fazer um fork e manter o código internamente com monitoramento contínuo de vulnerabilidades.
- C)** Adicionar uma regra de web application firewall para bloquear ataques direcionados à biblioteca.
- D)** Migrar a aplicação para outro provedor de nuvem com postura de segurança mais forte.

QUESTÃO 10 · CENÁRIO DE EXAME

Novas estações de trabalho chegam de um fornecedor com uma imagem de firmware modificada, e um chip implantado inicia uma conexão de saída no boot antes de o sistema operacional carregar. Qual controle MELHOR ajuda a organização a detectar esse tipo de adulteração?

- A)** Medição de boot (measured boot) baseada em TPM com atestação remota das medições de inicialização.
- B)** Antivírus baseado em host com atualizações diárias de assinaturas.
- C)** Allowlisting de aplicações aplicado no endpoint.
- D)** Um agente de prevenção de perda de dados (DLP) que inspeciona arquivos que saem da estação de trabalho.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — O código malicioso chegou dentro de uma atualização assinada digitalmente pelo fornecedor confiável, de modo que as verificações de confiança, hash e reputação foram todas aprovadas.

A essência de um ataque de cadeia de suprimentos pelo canal confiável é que a carga maliciosa é entregue dentro de algo em que a organização já confia. Como a atualização foi assinada com o certificado legítimo do fornecedor, a verificação de assinatura, a comparação de hash e as checagens de reputação foram todas bem-sucedidas, e não existia assinatura de antivírus para o implante. Esse é o padrão SolarWinds: comprometer o pipeline de build ou de distribuição do fornecedor uma vez e todos os clientes instalam o implante voluntariamente. Packing, adulteração de logs ou implantes de hardware descrevem outras técnicas e não foram o que fez este ataque específico funcionar.

Questão 2: Alternativa A — Um software bill of materials (SBOM) gerado a cada release e atualizado em cada build.

Um SBOM é um inventário formal e legível por máquina dos componentes, bibliotecas e versões que compõem um produto de software, incluindo dependências transitivas. É o artefato que permite ao fabricante (e aos seus clientes) responder rapidamente o que existe dentro de uma release e se uma vulnerabilidade recém-divulgada se aplica. Testes de intrusão, varreduras de vulnerabilidade em hosts e inventários de ativos descrevem ambientes ou resultados de testes, e não a composição do próprio software.

Questão 3: Alternativa C — Software composition analysis (SCA) integrado ao pipeline de CI/CD.

Ferramentas de SCA analisam manifests, lockfiles e árvores de dependência para inventariar componentes de terceiros e open-source, correlacioná-los com bases de vulnerabilidades e sinalizar obrigações de licença. Executar SCA no pipeline identifica dependências vulneráveis ou não conformes antes da liberação do build. SAST examina o código-fonte da própria equipe (não binários de terceiros), RASP protege em tempo de execução na produção, e FIM detecta alterações não autorizadas em arquivos, não o risco de componentes.

Questão 4: Alternativa B — Adquirir hardware de rede apenas por canais autorizados e verificar os hashes do firmware assinado pelo fabricante antes da implantação.

Hardware falsificado ou adulterado e firmware não autorizado são problemas de integridade da cadeia de suprimentos que devem ser tratados na origem da aquisição. Comprar somente de distribuidores autorizados e validar o firmware assinado pelo fabricante contra hashes publicados garante que o dispositivo não foi modificado entre a fábrica e o rack. Port security, gerenciamento out-of-band e NAC são controles de hardening valiosos, mas nenhum deles detecta ou impede um implante ou firmware modificado que já esteja no dispositivo.

Questão 5: Alternativa A — Impor um repositório interno curado de pacotes, com allowlist de pacotes aprovados e versões de dependência travadas.

Trata-se de typosquatting (uma forma de ataque de cadeia de suprimentos em pacotes open-source). Um registro interno curado, com allowlist e versões fixas verificadas por integridade, impede que pacotes não avaliados entrem no build — é a única opção que interrompe a instalação maliciosa em vez de apenas observá-la ou limitá-la. Um sistema de arquivos somente leitura não impede que um script de instalação leia variáveis de ambiente e as envie para fora, MFA não se aplica a um gerenciador de pacotes baixando uma dependência, e o log de DNS só oferece detecção depois que os tokens já saíram.

Questão 6: Alternativa A — Exigir commits assinados e assinar criptograficamente os artefatos de release com uma chave exclusiva de build à qual os desenvolvedores não têm acesso.

Uma vez que o adversário está dentro do pipeline, a defesa central é tornar artefatos não autorizados detectáveis e inutilizáveis adiante. A assinatura de commits vincula alterações a identidades verificadas, e assinar artefatos de release com uma chave exclusiva de build inacessível aos desenvolvedores faz com que um build adulterado não possa ser apresentado como release autêntica do fornecedor, pois a atestação de proveniência falhará. Frequência de atualização de dependências, um WAF e restrições de VLAN não tratam da integridade do código nem da proveniência da release na cadeia de build.

Questão 7: Alternativa B — Analisar o relatório de auditoria independente do provedor (por exemplo, SOC 2 Type II) e preencher um questionário de avaliação de risco de fornecedor.

A gestão de risco de terceiros para um fornecedor que trata dados sensíveis depende de evidências sobre o ambiente de controles do provedor. Um relatório SOC 2 Type II cobre o desenho e a efetividade operacional dos controles ao longo de um período, e um questionário estruturado de segurança preenche lacunas que o relatório não aborda (tratamento de dados, notificação de incidentes, subcontratados). Escanear apenas uma página de login testa quase nada, material de marketing não

é garantia, e provocar deliberadamente uma indisponibilidade na API de produção do provedor é antiético e provavelmente ilegal.

Questão 8: Alternativa B — Consultar o inventário de SBOM e SCA para identificar quais aplicações e imagens de contêiner incluem a versão comprometida.

O primeiro passo na resposta a um componente de terceiros comprometido é delimitar o escopo: determinar quais sistemas realmente contêm a versão afetada. Um inventário de SBOM ou SCA responde a essa pergunta com rapidez e precisão, permitindo que remediação, contenção e notificação sejam direcionadas. Bloqueios de rede generalizados, notificações em massa a clientes e reconstruções totais são ações disruptivas, caras e prematuras quando ainda não se conhece a exposição real.

Questão 9: Alternativa B — Substituir a biblioteca por uma alternativa mantida ativamente, ou fazer um fork e manter o código internamente com monitoramento contínuo de vulnerabilidades.

Um pacote open-source sem manutenção e sem dono claro é um risco de cadeia de suprimentos porque ninguém o corrige e porque um nome de pacote ou conta de repositório abandonados podem ser assumidos e republicados com código malicioso. A correção duradoura é eliminar a dependência migrando para uma biblioteca mantida, ou internalizar o risco fazendo um fork e mantendo o código com monitoramento e correção contínuos de vulnerabilidades. Código inalterado ainda pode ser explorado por falhas recém-descobertas, e regras de WAF ou migração de nuvem não resolvem um componente não corrigido dentro da aplicação.

Questão 10: Alternativa A — Medição de boot (measured boot) baseada em TPM com atestação remota das medições de inicialização.

Um implante de hardware ou firmware que age antes de o sistema operacional carregar opera abaixo da visibilidade de qualquer controle baseado em software no host. O measured boot registra hashes criptográficos de cada estágio de inicialização no TPM, e a atestação remota compara essas medições com valores conhecidos como bons, de modo que uma imagem de firmware modificada gera uma divergência detectável. Antivírus, allowlisting e DLP executam depois que o sistema operacional está no ar e não conseguem ver atividade pré-boot nem firmware alterado.